

Exercice : Plan de Continuité d'Activité (PCA)

Étude de cas : TechNégoce

1) Identifier les activités critiques

Voici 5 activités critiques pour TechNégoce, avec leur justification et les conséquences d'une interruption de 24h.

a) Gestion des commandes clients

- **Importance** : C'est le cœur de l'activité commerciale. Sans cela, aucune vente ne peut être enregistrée, traitée ou suivie.
- **Conséquences (24h d'arrêt)** : Perte de chiffre d'affaires direct, mécontentement des clients pouvant aller voir la concurrence, retard dans tout le cycle de vente (préparation, livraison).

b) Accès au logiciel de gestion commerciale

- **Importance** : Centralise toutes les données vitales : clients, produits, stocks, factures. Indispensable à la fois pour les ventes et la gestion administrative.
- **Conséquences (24h d'arrêt)** : Impossibilité de créer des devis, de facturer, de suivre les paiements. L'activité commerciale et administrative est paralysée.

c) Accès aux fichiers de l'entreprise

- **Importance** : Les employés ont besoin d'accéder aux documents partagés (propositions commerciales, documents techniques, etc.) pour travailler efficacement.
- **Conséquences (24h d'arrêt)** : Forte baisse de productivité. Les employés ne peuvent pas accéder à leurs outils de travail quotidiens, retardant tous les projets en cours.

d) Connexion Internet

- **Importance** : Essentielle pour la communication (emails, téléphonie sur IP si utilisée), la gestion du site vitrine, et potentiellement l'accès à des services cloud.
- **Conséquences (24h d'arrêt)** : Plus de communication avec l'extérieur (clients, fournisseurs). Le site vitrine n'est plus administrable. L'image de l'entreprise est dégradée.

e) Service de facturation

- **Importance** : La facturation est vitale pour la trésorerie de l'entreprise. Sans facturation, pas de rentrée d'argent.
- **Conséquences (24h d'arrêt)** : Retards de paiement des clients, impact direct sur la trésorerie et le besoin en fonds de roulement. Peut créer des tensions avec les clients et les services comptables.

2) Identifier les risques majeurs

Analyse de 5 risques majeurs pour TechNégoce.

a) Cyberattaque (Rançongiciel)

- **Probabilité** : Moyenne. Les PME sont des cibles privilégiées et les attaques par rançongiciel sont en constante augmentation. Une erreur humaine (phishing) peut facilement en être la cause.
- **Gravité** : Forte. Potentiellement toutes les données de l'entreprise sont chiffrées et inaccessibles (fichiers, base de données commerciale).
- **Impact** : Très élevé. Arrêt complet de l'activité, perte de données potentiellement irrécupérable, impact financier majeur (rançon, coûts de remise en service), atteinte à la réputation.

b) Panne du serveur de fichiers

- **Probabilité** : Moyenne. Dépend de l'âge et de la qualité du matériel. Une panne disque ou une défaillance d'un composant (alimentation) est un scénario classique.
- **Gravité** : Moyenne. L'impact est limité à l'accès aux documents. Le logiciel de gestion et les autres services peuvent rester fonctionnels.
- **Impact** : Important. Baisse de productivité des 20 utilisateurs. Entrave le bon déroulement des processus métiers qui s'appuient sur des documents partagés.

c) Perte de la connexion Internet

- **Probabilité** : Moyenne. L'opérateur peut subir une panne, ou des travaux peuvent endommager la ligne. Le fait d'avoir une seule connexion fibre augmente ce risque.
- **Gravité** : Moyenne. L'activité interne principale (gestion commerciale sur site) peut continuer, mais toute la communication externe est coupée.
- **Impact** : Important. Plus d'email, plus d'accès à l'administration du site web, pas de nouvelles commandes via le web. L'entreprise est isolée.

d) Panne électrique

- **Probabilité** : Faible. Les coupures de courant générales sont rares, mais peuvent arriver (travaux, incident sur le réseau).
- **Gravité** : Forte. Aucun équipement informatique ne fonctionne : serveurs, postes de travail, réseau.
- **Impact** : Très élevé. Arrêt total et immédiat de toute l'activité de l'entreprise.

e) Incendie ou dégât des eaux

- **Probabilité** : Faible. C'est un risque rare mais dévastateur.
- **Gravité** : Très Forte. Destruction potentielle des infrastructures (serveurs, postes), des documents papier, et mise en danger des employés.
- **Impact** : Catastrophique. Arrêt complet et prolongé de l'activité. Coûts de reconstruction immenses. Perte de données potentiellement définitive si les sauvegardes sont aussi sur site.

3) RTO et RPO

a) Définitions

- **RTO (Recovery Time Objective)** : C'est la *durée maximale d'interruption admissible* pour une ressource informatique (serveur, application). En d'autres termes, c'est le temps maximal que l'entreprise se donne pour remettre en service un élément après une panne. Un RTO de 2h signifie que le service doit être rétabli en moins de 2 heures.
- **RPO (Recovery Point Objective)** : C'est la *perte de données maximale admissible* lors d'une panne. Il s'exprime en durée et correspond à la période entre la dernière sauvegarde utilisable et le moment de l'incident. Un RPO de 4h signifie que l'entreprise accepte de perdre au maximum 4 heures de données saisies avant la panne.

b) Propositions pour TechNégoce

Le logiciel de gestion commerciale

- **RPO proposé : 15 minutes**. Les données commerciales (commandes, factures, clients) sont très volatiles et critiques. Une perte de plus de quelques minutes de saisie serait très coûteuse à rattraper et pourrait causer des erreurs commerciales graves.
- **RTO proposé : 2 heures**. L'activité commerciale étant le cœur de métier de TechNégoce, il est impératif de pouvoir reprendre les ventes le plus rapidement possible. 2 heures représentent un maximum acceptable pour ne pas paralyser l'entreprise.

Le serveur de fichiers

- **RPO proposé : 24 heures**. Les documents bureautiques sont moins critiques et moins volatils que les données de gestion. Une sauvegarde par nuit semble un compromis acceptable entre sécurité et coût. Les utilisateurs peuvent souvent récupérer une version locale de leur travail en cours.
- **RTO proposé : 8 heures (une journée de travail)**. Bien que pénalisant, l'indisponibilité des fichiers partagés n'empêche pas totalement le travail (contrairement au logiciel de gestion). Un rétablissement dans la journée est un objectif réaliste et suffisant.

Le réseau interne

- **RPO proposé : N/A (Non Applicable)**. Le réseau est une infrastructure, il ne stocke pas de données. Le RPO ne s'applique donc pas ici.
- **RTO proposé : 4 heures**. Le réseau est le socle qui permet l'accès à tous les autres services (serveur de fichiers, logiciel de gestion). Son rétablissement est une priorité élevée pour rendre le reste du système d'information de nouveau opérationnel.

4) Définir les solutions de continuité

Tableau des mesures de continuité pour chaque risque identifié.

Risque	Mesures Préventives	Mesures Curatives / de Reprise
Cyberattaque (Rançongiciel)	- Formation des utilisateurs (anti-phishing). - Antivirus et pare-feu à jour. - Politique de mots de passe robustes. - Cloisonnement du réseau.	- <i>Isoler la machine infectée</i> du réseau immédiatement. - Restaurer les données à partir de sauvegardes saines (stratégie 3-2-1 : 3 copies, 2 supports, 1 hors site). - Ne jamais payer la rançon.
Panne du serveur de fichiers	- Maintenance régulière du serveur. - Surveillance des indicateurs de santé (disques, température). - Avoir des pièces de rechange critiques (disques, alimentation).	- Mettre en place un serveur de secours (NAS) prêt à prendre le relais. - Restaurer les données depuis la dernière sauvegarde sur le serveur de secours.
Perte de la connexion Internet	- Contrat de service (GTR) avec l'opérateur.	- Mettre en place une double connexion Internet (Fibre + 4G/5G ou ADSL) avec basculement automatique (failover).
Panne électrique	- Protéger les équipements sensibles (serveurs, switches) avec des onduleurs (UPS).	- Définir une procédure d'arrêt propre des serveurs en cas de coupure prolongée. - Pour une continuité totale : groupe électrogène, mais le coût est élevé pour une PME.
Incendie / Dégât des eaux	- Détecteurs de fumée et extincteurs. - Salle serveur propre, loin des points d'eau. - Ne pas stocker de matériel inflammable près des serveurs.	- La mesure la plus critique : avoir des <i>sauvegardes externalisées</i> (cloud ou autre site physique). - Activer le Plan de Reprise d'Activité (PRA) si un site de secours est prévu.

5) Synthèse : Mini Plan de Continuité d'Activité (PCA)

Ce document synthétise le plan de continuité pour l'entreprise TechNégoce.

a) Activités Critiques et Objectifs de Reprise

- **Gestion des commandes et facturation** : RTO 2h, RPO 15 min. Cœur du métier.
- **Accès aux fichiers partagés** : RTO 8h, RPO 24h. Important pour la productivité.
- **Connectivité (Interne & Externe)** : RTO 4h. Socle de tous les services.

b) Risques Majeurs et Solutions Retenues

Risque	Solution Clé
Cyberattaque	Sauvegardes externalisées et déconnectées (immuables).
Panne Matérielle (Serveur)	Serveur de secours (NAS) avec restauration des données.
Perte Connexion Internet	Double lien Internet (Fibre + 4G) en failover.
Panne Électrique	Onduleurs sur les équipements critiques (serveurs, réseau).
Incendie / Dégât des Eaux	Sauvegardes externalisées quotidiennes.

c) Procédures d'Urgence en cas d'Incident Majeur

En cas de sinistre avéré (panne générale, cyberattaque, etc.), suivre les étapes suivantes :

1. **Contactez le responsable informatique** : Il est le seul habilité à déclarer l'état de crise.
2. **Communication interne** : Informer immédiatement les employés de la nature de l'incident et des consignes à suivre (ex : "Ne plus utiliser les ordinateurs", "Passer sur les procédures papier").
3. **Activation des solutions** :
 - **Panne électrique > 30min** : Arrêt propre des serveurs via les onduleurs.
 - **Cyberattaque suspectée** : Débrancher physiquement les serveurs et postes du réseau.
 - **Panne d'un serveur critique** : Basculement sur le matériel de secours.
4. **Communication externe** : Préparer un message à destination des clients si l'impact dépasse le RTO annoncé (ex : "Suite à un incident technique, nos services sont momentanément interrompus...").
5. **Journal de crise** : Tenir un registre de toutes les actions menées (qui, quoi, quand) pour faciliter l'analyse post-mortem.